پاسخ فنی به سند درخواست پیشنهاد (RFP)

پروپوزال فنی

طراحی و پیاده‌سازی سامانه هوشمند گزارش‌ساز SQL مبتنی بر هوش مصنوعی و تولید امن

ویژه سرویس‌دهی متمرکز به نرم‌افزارهای سازمانی On-Premise

عنوان	مقدار
مخاطب	کارفرمای پروژه سامانه هوش مصنوعی
تهیه‌کننده	علی عمرانی
نسخه سند	۱.۰
تاریخ	مرداد ۱۴۰۵ ۵
زمان اجرای پیشنهادی	هفته تقویمی +۳۰ روز پشتیبانی تثبیت ۲۰
مسیر فنی منتخب	Vendor-Neutral Approved Stack

نتیجه پیشنهادی

تحویل یک سکوی چندنرم‌افزاری و چندنسخه‌ای که درخواست فارسی کاربر را به SQL پارامتری، کنترل‌شده و قابل ممیزی تبدیل می‌کند؛ بدون دسترسی مستقیم سرویس مرکزی به دیتابیس شهرداری.

محرمانگی: این سند برای ارزیابی فنی و قراردادی پروژه تهیه شده است.

خلاصه مدیریتی

دریافتی، هدف پروژه ایجاد یک سامانه متمرکز هوش مصنوعی است که به نرم‌افزارهای سازمانی نصب‌شده در RFP بر اساس محل شهرداری‌ها خدمت ارائه دهد .این سامانه متن درخواست گزارش را همراه با شناسه نرم‌افزار، نسخه، کاربر و اطلاعات استاندارد و مشخصات نمایش SQL ،احراز هویت دریافت می‌کند و پس از کنترل دسترسی و مراجعه به دانش همان نسخه انجام می‌شود و سرویس مرکزی به دیتابیس On-Premise و نمایش داده در محیط SQL خروجی را بازمی‌گرداند .اجرای عملیاتی دسترسی مستقیم نخواهد داشت.

پیشنهاد اجرایی

پروژه در ۲۰ هفته تقویمی اجرا شود .نسخه پایلوت قابل اتصال در پایان هفته ۱۰، نسخه کامل پیش‌تولید در پایان هفته ۱۷ و استقرار نهایی پس از آزمون پذیرش در پایان هفته ۲۰ تحویل می‌شود.

است .این انتخاب با هسته موجود پروژه که بر Vendor-Neutral یعنی استک RFP مسیر فنی پیشنهادی، گزینه دوم استوار است React و رابط Python، FastAPI، Hybrid RAG، Schema Graph، SQL Validator لایه‌های RFP، بیشترین هم‌پوشانی را دارد .اجزای تولیدشده قبلی به‌عنوان دارایی اولیه استفاده می‌شوند، اما برای انطباق کامل با پنل‌های چندسطحی، شارژ و پرداخت، مدیریت نسخه دانش، مشاهده‌پذیری و سخت‌سازی API، سازمانی احراز هویت، درگاه امنیتی توسعه و یکپارچه خواهند شد.

فهرست مطالب

- ۱. درک مسئله و اهداف پروژه
- ۲. وضعیت فعلی و دارایی‌های قابل استفاده
- ۳. دامنه راهکار پیشنهادی
- ۴. معماری کلان و جریان پردازش
- ۵. طراحی فنی ماژول‌ها و پنل‌ها
- ۶. امنیت، محرمانگی و کنترل SQL
- ۷. استک فناوری منتخب
- ۸. یکپارچه‌سازی API و On-Premise
- ۹. برنامه زمان‌بندی ۲۰ هفته‌ای
- ۱۰. تحویل‌دادنی‌ها، معیار پذیرش و تیم
- ۱۱. پیش‌نیازها، ریسک‌ها و موارد خارج از دامنه
- پیوست الف :ماتریس انطباق با RFP
- پیوست ب :نمونه قرارداد API

۱. درک مسئله و اهداف پروژه

مسئله اصلی صرفاً اتصال یک مدل زبانی به چند فایل نیست .سامانه باید در یک محیط چندنرم‌افزاری، چندنسخه‌ای و چندکاربری، درخواست طبیعی فارسی را به گزارش قابل اتکا تبدیل کند و همزمان از افشای ساختار دیتابیس، دور زدن

و تزریق پرامپت جلوگیری کند .بنابراین معماری باید ترکیبی از مسیرهای قطعی، بازیابی دانش SQL دسترسی، تزریق اعتبارسنج مستقل و ممیزی کامل باشد ،SQL نسخه‌ای، گراف روابط اسکیما، برنامه‌ریزی کوئری، تولید محدودشده.

- فقط برای نرم‌افزار، نسخه و دامنه مجاز درخواست‌کننده SQL تولید.
- بازگرداندن نوع نمایش استاندارد شامل جدول، متن یا پیام عدم امکان تولید گزارش.
- حفظ جداسازی کامل دانش نسخه‌ها و امکان ارجاع کنترل‌شده بین نسخه‌های وابسته.
- سیاست هزینه و کنترل سلامت مدل ،Failover پشتیبانی از مدل‌های ابری و محلی همراه با.
- های قطعی برای درخواست‌های پرتکرارRecipe و Semantic Cache، Exact Cache کاهش هزینه با.
- ثبت رخدادهای امنیتی، مصرف، کیفیت، نظر کاربر و نتیجه اعتبارسنجی به‌شکل قابل گزارش.
- فراهم‌کردن پنل مالک سامانه و پنل مدیر نرم‌افزار مطابق سطوح اختیار RFP.

۲. وضعیت فعلی و دارایی‌های قابل استفاده

فارسی و نیز موتور استانداردسازی اسناد NL2SQL و RAG تخصصی برای MVP یک ،RFP تا پیش از دریافت پیاده‌سازی شده است .این دارایی‌ها زمان بخش هسته هوش مصنوعی را کاهش می‌دهند، اما به‌تنهایی معادل محصول سازمانی نهایی نیستند.

مرزبندی تعهد

را محاسبه می‌کند؛ بنابراین زمان پروژه فقط RFP به محصول سازمانی منطبق با MVP پروپوزال حاضر زمان لازم برای تبدیل نیز هست UAT نیست و شامل امنیت، پنل‌ها، مالی، استقرار و RAG زمان تولید مدل یا.

شرح	دارایی/ماژول	وضعیت
و مستندات با بازرتبه‌بندی SQL ،بازیابی ترکیبی اسکیما	Hybrid Retrieval و Reranking	موجود
و روابط واقعی/منطقی Join مدل‌سازی مسیرهای	Schema/Relationship Graph	موجود
جداول/ستون‌ها، الگوهای خطرناک و محدودیت خروجی، Read-only کنترل	Query Plan و SQL Validator	موجود
مسیر قطعی برای سؤال‌های حیاتی و ۲۰ سؤال پذیرش	Deterministic Recipes	موجود
Manifest و Human Review ،دسته‌بندی، امتیاز کیفیت، تعارض	موتور استانداردسازی اسناد	موجود
اولیه برای آزمایش RTL و پنل API، CLI هسته	اولیه React و رابط FastAPI	موجود
و امنیت HA ،پنل‌ها، مالی، Multi-Tenancy، Kong، Keycloak	لایه‌های سازمانی و Production	نیازمند توسعه
TailwindCSS و Next.js به React/Vite مهاجرت	Frontend	نیازمند مهاجرت

۳. دامنه راهکار پیشنهادی

۳-۱. قابلیت‌های هسته گزارش‌ساز

- دریافت درخواست فارسی و نرمال‌سازی نگارشی، اعداد و اصطلاحات سازمانی.

- موجودیت‌ها، نرم‌افزار هدف، نسخه و نوع گزارش، Intent تشخیص.
- تأییدشده نسخه مربوطه Snapshot بازیابی دانش صرفاً از.
- قطعی برای درخواست‌های پرتکرار و حساس Recipe استفاده از.
- بازیابی‌شده Schema Slice و محدودکردن مدل به SQL قبل از Query Plan تولید.
- نرم‌افزار و جلوگیری از الحاق مستقیم مقادیر کاربر Dialect پارامتری مطابق SQL تولید.
- Timeout Policy. و Row Limit، ها، توابعJoin، جداول، ستون‌ها، AST اعتبارسنجی
- شامل نوع نمایش، ستون‌ها، عنوان، قالب اعداد و پیام‌های کاربری Display Spec تعیین.
- Chain-of-Thought. بدون افشای Validator منابع دانش، شناسه ممیزی و وضعیت، Confidence ثبت

۳-۲. مدیریت دانش نسخه‌ای

- تعریف Software، Version و Knowledge Snapshot مستقل با وضعیت Draft، Review، Approved و Retired.
- و تست‌ها Glossary، روابط، قواعد کسب‌وکار، Markdown، SQL، DDL بارگذاری و استانداردسازی.
- و جلوگیری از ورود فایل تکراری یا متناقض Hash جایگزینی افزایشی فایل‌های تغییرکرده بر اساس.
- صریح Override و Inheritance ارجاع نسخه جدید به نسخه پایه با سیاست.
- اتمیک؛ درخواست فعال هرگز ترکیبی از نسخه نیمه‌بارگذاری‌شده دریافت نمی‌کند Snapshot انتشار.
- قبلی و نگهداری تاریخچه تغییر و تأییدکننده Rollback به Snapshot.

۳-۳. پنل مالک سامانه

- تعریف، ویرایش، فعال/غیرفعال و حذف منطقی مدیر نرم‌افزار.
- Audit Trail. انتقال سوابق مدیریتی به مدیر دیگر همراه با
- تعریف نقش و سطح دسترسی مدیران به نرم‌افزارها، داده‌ها و گزارش‌ها.
- مدیریت اعتبار، تعرفه مصرف، سقف درخواست، سهمیه و تاریخچه تراکنش.
- مدیریت درگاه پرداخت آنلاین و تطبیق تراکنش‌ها با کیف اعتبار.
- داشبورد آماری مصرف، کیفیت، خطا، امنیت، درآمد و سلامت مدل‌ها.
- Correlation ID. مدل و API، جست‌وجو و فیلتر لاگ بر اساس کاربر، نرم‌افزار، نسخه، کلید

۳-۴. پنل مدیر نرم‌افزار

- تعریف نرم‌افزار مستقل یا وابسته و مدیریت نسخه‌های آن.
- بارگذاری، ویرایش، مقایسه و انتشار دانش هر نسخه.
- تعریف کاربران نرم‌افزار، نقش، سقف مصرف، وضعیت و دسترسی موضوعی.
- برای نرم‌افزار و کاربران API Key صدور، چرخش، ابطال و محدودسازی.
- اطلاعات حساس Redaction مانیتورینگ درخواست‌ها و مشاهده پرامپت/پاسخ با.
- ثبت ارزیابی سه‌گانه کیفیت: نظر کاربر، ارزیابی خودکار سامانه و نظر مدیر.
- یا داده آموزشی Recipe مدیریت پاسخ‌های کش‌شده و تبدیل نمونه‌های تأییدشده به.

۴. معماری کلان و جریان پردازش

معماری پیشنهادی به‌صورت Defense-in-Depth. سامانه مرکزی فقط SQL طراحی می‌شود و مشخصات نمایش را SQL و سیاست Dialect، TTL، داخل شبکه شهرداری پیش از اجرا، امضا Connector. تولید می‌کند را دوباره بررسی

می‌کند .داده خام دیتابیس به سرویس هوش مصنوعی ارسال نمی‌شود، مگر در یک قابلیت مجزا که بعداً با رضایت و قرارداد مستقل تعریف شود.

گام	مولفه	عملکرد
۱	نرم‌افزار On-Premise	ارسال متن، software_id، version، user، scope claims و token
۲	Kong + Keycloak	اعتبارسنجی، Rate Limit، API Key/JWT، tenant و quota
۳	Policy Engine	کنترل موضوع، مجوز گزارش، جداول و ستون‌های قابل استفاده
۴	NL2SQL Orchestrator	Intent → Entities → Recipe/RAG → Rerank → Schema Slice → Plan
۵	SQL Guard	AST Validation، پارامتری‌سازی، Allowlist، Row Limit و Risk Score
۶	Response Service	SQL، Parameters، Display Spec، Confidence و Audit ID
۷	On-Premise Executor	بازاعتبارسنجی محلی، اجرای Read-only و نمایش نتیجه
۸	Telemetry	ثبت متادیتای مصرف، زمان، نتیجه و بازخورد بدون ذخیره داده حساس

۴-۱. مسیر قطعی و مسیر هوشمند

درخواست‌های حیاتی و شناخته‌شده

خروجی .این مسیر برای ۲۰ سؤال پذیرش و Recipe تأییدشده → Schema پارامترها → واقعی → Validator → گزارش‌های پرتکرار ثبات بسیار بالا ایجاد می‌کند.

درخواست‌های جدید

Hybrid RAG + Schema Graph + Reranker + Constrained LLM → Query Plan → SQL Validator → خروجی .در صورت ابهام یا ریسک بالا، سامانه به‌جای حدس‌زدن، درخواست تکمیل اطلاعات می‌کند.

۵. طراحی فنی ماژول‌های کلیدی

ماژول	شرح فنی
Identity & Tenant	Keycloak؛ Realm/Client/Role، OAuth2/OIDC، JWT، MFA و مدیران Service Account
API Gateway	Kong؛ Rate Limit، API Key، mTLS اختیاری، Quota، IP Policy و Request Size Limit
Knowledge Registry	Software/Version/Snapshot/File/Approval/Dependency و Change Audit
Document Standardizer	Quality Score و Conflict، Grounding، استخراج ساختار، طبقه‌بندی ۹ نوع سند

ماژول	شرح فنی
Hybrid Retrieval	BM25/Elasticsearch + pgvector، فیلتر tenant/software/version و Reranking
Schema Graph	روابط FK و منطقی، Cardinality، Join Path و کنترل تکثیر رکورد
Query Planner	Intent، Entities، Grain، Tables، Filters، Aggregations، Order و Display Intent
SQL Generator	T-SQL/SQL dialect، Structured Output و تولید پارامتری
SQL Security Gateway	AST Parse، Read-only، Allowlist، Forbidden Functions، Limit و Complexity
Model Router	Cloud/Local، Health Check، Circuit Breaker، Cost Policy و Automatic Failover
Cache	Exact + Semantic Cache با کلید شامل نسخه دانش، دسترسی و سیاست امنیتی
Billing	Wallet، Tariff، Reservation/Settlement، Transaction Ledger و Payment Reconciliation
Audit & Observability	OpenTelemetry، Elastic APM، Prometheus/Grafana و JSON Logs
Admin Web	Next.js + TailwindCSS، RTL، RBAC، مدیریت دانش، کلید، کاربر، مصرف و کیفیت

۵-۱. راهبرد چندمدلی و کاهش هزینه

هزینه، دسترس‌پذیری و سیاست هر نرم‌افزار تصمیم Context، بر اساس نوع درخواست، حساسیت، طول Router مدل سرو می‌شود و مدل‌های ابری فقط در صورت مجازبودن سیاست مستأجر استفاده TGI یا vLLM می‌گیرد. مدل محلی با Failover به مدل ابری بدون اجازه صریح مدیر نرم‌افزار رخ نمی‌دهد. هیچ‌وقت می‌شوند.

- Recipe Cache برای پرسش‌های قطعی و پرتکرار.
- Exact Cache برای درخواست کاملاً یکسان با همان نسخه دانش و همان Scope.
- Semantic Cache فقط پس از بررسی برابری Intent، Entities، Version و Access Fingerprint.
- Schema Slice به‌جای کل اسکیما و ارسال Context فشرده‌سازی.
- Cache Hit برای تصمیم‌گیری تعرفه‌ای زمان مدل و Token، ثبت هزینه.

۶. امنیت، محرمانگی و کنترل SQL

تهدید	کنترل پیشنهادی
افشای ساختار دیتابیس	enumerate برای endpoint هیچ API داخلی نگهداری می‌شود؛ Schema تنها در Knowledge Service کردن جداول ندارد و پاسخ خطا نام موجودیت داخلی را افشا نمی‌کند.
دسترسی خارج از مجوز	محلی دوباره کنترل Connector اعمال و در scope و role، version، software، tenant بر اساس Policy می‌شود.
SQL Injection	پیش از تحویل اجرا Forbidden Token/Function و AST Parse هستند؛ Parameter مقادیر کاربر فقط می‌شود.
Prompt Injection	از اسناد، پاک‌سازی محتوا، برچسب منبع، عدم تبعیت از دستور داخل سند و آزمون System Policy جداسازی adversarial.

تهدید	کنترل پیشنهادی
دور زدن دسترسی	Allowlist جدول/ستون، Row-Level Template، امضای Policy Context و جلوگیری از JOIN خارج از Schema Slice.
عملیات مخرب	رد INSERT/UPDATE/DELETE/MERGE/EXEC/DDL/Temp Table و Queryهای چنددستوری.
استخراج حجیم	TOP/Limit اجباری، Complexity Budget، Timeout، سقف ردیف و Rate Limit.
نشت در لاگ	Redaction توکن، کلید، شناسه‌های حساس و پارامترهای طبقه‌بندی‌شده؛ رمزگذاری در انتقال و ذخیره.
سرقت API Key	Hash امن، Rotation، Expiry، Prefix قابل شناسایی، Scope، IP Restriction و Revocation فوری.
حمله به مدل	Model timeout، Circuit Breaker، Sandbox منطقی، Structured Output و عدم اجرای مستقیم متن مدل.

اصل امنیتی کلیدی

Connector بدون اعتبارسنجی مستقل اجرا نمی‌شود On-Premise تأییدشده سرویس مرکزی نیز در محیط SQL حتی Viewهای گزارش‌گیری متصل باشد محدود و دسترسی حداقلی به Read-only، Timeout محلی باید با حساب.

۶-۱. سیاست داده و لاگ

- تولیدشده، متادیتا، امتیازها و رخدادها ثبت می‌شوند؛ داده نتیجه دیتابیس ذخیره SQL، به‌صورت پیش‌فرض فقط متن درخواست نمی‌شود.
- کردن شناسه‌های کاربر و پارامترهای حساس فراهم می‌شود Hash یا Mask امکان.
- لاگ، پرامپت و تراکنش برای هر مستأجر قابل تنظیم و مطابق قرارداد خواهد بود Retention.
- correlation_id و IP، timestamp، before/after، target، action، actor گزارش ممیزی شامل است.
- Runbook استقرار مستند می‌شود و سیاست حذف امن در Restore رمزگذاری‌شده، تست Backup.

۷. استک فناوری منتخب

RFP پیشنهاد فنی بر مبنای گزینه دوم و بدون استفاده از فناوری خارج از الگوی مجاز ارائه می‌شود. نسخه دقیق اجزا در SBOM ثبت خواهد شد و در Pin مرحله طراحی تفصیلی.

لایه	فناوری
Backend	Python 3.12، FastAPI، Pydantic، SQLAlchemy/Alembic، Celery/Task Worker
Identity	Keycloak با OAuth2، OpenID Connect، JWT و MFA
Gateway	Kong Gateway با Rate Limiting و API Key Management
Core Database	PostgreSQL برای تنظیمات، نسخه‌ها، کاربر، مالی و متادیتا
Time Series	TimescaleDB برای رخداد مصرف و عملکرد
Cache	Redis برای Cache، Lock، Rate State و Job State

لایه	فناوری
Logs/Search	Elasticsearch برای لاگ و جست‌وجوی مدیریتی
Vector	pgvector؛ فقط برای حالت تک‌گره آزمایشی FAISS برای بردارهای دانش
AI Orchestration	LlamaIndex/LangChain در کنار Orchestrator و Validator مستقل
Models	OpenAI/Claude/Gemini در Cloud و Qwen2.5/LLaMA/Mistral/DeepSeek در Local
Model Runtime	vLLM یا TGI بر اساس GPU و مدل نهایی
Observability	OpenTelemetry، Elastic APM، Prometheus و Grafana
Frontend	React + Next.js + TailwindCSS با رابط فارسی RTL
Deployment	Docker؛ Kubernetes در صورت نیاز HA و مقیاس سازمانی

۸. API و یکپارچه‌سازی On-Premise

۸-۱. قرارداد ورودی پیشنهادی

فیلد	نوع	کاربرد
request_id	UUID	شناسه یکتا برای Audit و Idempotency
software_id	string	شناسه نرم‌افزار ثبت‌شده
software_version	string	نسخه دقیق دانش
user_id	string	شناسه کاربر در نرم‌افزار مبدأ
question	string	شرح فارسی گزارش
access_context	signed object	Role، Region، Organization و Scope های مجاز
locale/timezone	string	قالب تاریخ، زبان و منطقه زمانی

۸-۲. قرارداد خروجی پیشنهادی

فیلد	شرح
status	success / needs_clarification / rejected
sql	پارامتری تأییدشده؛ در حالت رد، خالی
parameters	نام، نوع و مقدار پارامترها به‌صورت جدا از SQL
display	table/text، عنوان، ستون‌ها، قالب عدد/تاریخ و ترتیب

فیلد	شرح
confidence	امتیاز کالیبره‌شده و سطح low/medium/high
audit_id	شناسه پیگیری برای پشتیبانی و گزارش امنیتی
policy	نسخه دانش/سیاست hash و timeout، حد ردیف

محلی دوباره parser را با SQL، سیاست و تاریخ انقضای پاسخ را کنترل کند hash محلی باید Connector اجرا کند .نتیجه گزارش مستقیماً به کاربر نمایش داده می‌شود و برای Read-only اعتبارسنجی نماید و فقط با حساب دیتابیس سرویس مرکزی ارسال نمی‌گردد.

۹. برنامه زمان‌بندی پیشنهادی

مدت کل

هفته تقویمی از تاریخ تحویل پیش‌نیازها و صورت‌جلسه شروع .پایلوت قابل اتصال در پایان هفته ۱۰ و دوره پشتیبانی تثبیت ۲۰ روز پس از تحویل نهایی در نظر گرفته شده است ۳۰.

فاز	عنوان	هفته	خروجی
۰	آغاز و تثبیت دامنه	۱	پرسش‌های باز، دسترسی‌ها، برنامه ارتباطی Kickoff،
۱	تحلیل و طراحی تفصیلی	۱-۲	SRS، Threat Model، API Contract، Data Model و UX Map
۲	زیرساخت و امنیت پایه	۳-۵	Keycloak، Kong، Tenant، CI/CD، Secrets و محیط‌ها
۳	Ingestion دانش نسخه‌ای و	۴-۷	Registry، Snapshot، Standardizer، Approval و Rollback
۴	هسته NL2SQL امن	۶-۱۰	Recipe/RAG/Graph، Planner، Generator، Validator و ۲۰ تست طلایی
نقطه عطف	پایلوت اتصال‌پذیر	پایان ۱۰	هسته، یک نرم‌افزار/نسخه و گزارش‌های پذیرش اولیه API
۵	پنل‌های مالک و مدیر	۸-۱۳	نرم‌افزار، نسخه، دانش، کاربران، نقش‌ها، کلیدها و لاگ
۶	شارژ، مالی و پرداخت	۱۱-۱۴	سهمیه، مصرف و اتصال درگاه منتخب Ledger، تعرفه
۷	و مانیتورینگ Cache ،چندمدلی	۱۲-۱۵	Router، Failover، Semantic Cache، APM و Dashboard
۸	یکپارچه‌سازی با بهساز	۱۴-۱۷	Connector SDK، محیط Stage، آزمون End-to-End
۹	امنیت، بار و اصلاح	۱۷-۱۸	Pen-test داخلی، Load Test، Backup/Restore و رفع نقص
۱۰	استقرار و آموزش UAT،	۱۹-۲۰	و تحویل مستندات Go-Live ،آموزش Runbook، پذیرش
پشتیبانی	تثبیت پس از تحویل	روز ۳۰	رفع اشکال، مانیتورینگ و دو نوبت بازبینی کیفیت

نقاط عطف قراردادی پیشنهادی ـ ۹-۱

نقطه عطف	زمان	معیار تحویل
M1	پایان هفته ۲	API Contract مدل امنیت و SRS، تأیید معماری
M2	پایان هفته ۵	Stage و محیط Tenant، Gateway، احراز هویت
M3	پایان هفته ۱۰	با یک نرم‌افزار/نسخه و تست‌های طلایی NL2SQL پایلوت
M4	پایان هفته ۱۴	پنل‌ها، شارژ، پرداخت و مدیریت دانش نسخه‌ای
M5	پایان هفته ۱۷	و یکپارچه‌سازی بهساز Pre-Production نسخه
M6	پایان هفته ۲۰	استقرار نهایی، آموزش و تحویل UAT،

تحویل‌دادنی‌ها ـ ۱۰

- کد منبع Backend، AI Services، Frontend و Connector/SDK نمونه.
- اسکریپت‌های دیتابیس و Migrationها، Seed های پایه و سیاست Backup/Restore.
- مطابق زیرساخت نهایی Production استقرار Manifest؛ Stage محیط توسعه و Docker Compose.
- مستند معماری کلان و تفصیلی، Threat Model، API/OpenAPI و مدل داده.
- راهنمای نصب، تنظیم، مانیتورینگ، بازیابی بحران و عملیات Runbook.
- راهنمای کاربری پنل مالک و پنل مدیر نرم‌افزار به زبان فارسی.
- مجموعه تست خودکار Unit، Integration، Security، E2E و Gold Acceptance.
- ماتریس پوشش الزامات NL2SQL گزارش تست بار، تست امنیت، کیفیت و.
- پکیج دانش نمونه برای یک نرم‌افزار/نسخه و دستورالعمل افزودن نسخه‌های بعدی.
- جلسات آموزش مدیر سامانه، مدیر نرم‌افزار و تیم فنی کارفرما.
- فهرست وابستگی‌ها، نسخه اجزا و شرایط مجوز نرم‌افزارهای متن‌باز، SBOM.

معیارهای پذیرش پیشنهادی ـ ۱۱

معیار پیشنهادی	شاخص
های تأییدشده و داده آزمون ثابتRecipe عبور معنایی برای ۱۰۰٪	صحت ۲۰ سؤال توافق‌شده
حداقل ۹۰٪ صحت معنایی در مجموعه آزمون مورد توافق	Benchmark پرسش‌های جدید
یا چنددستوری DML/DDL/EXEC پذیرفته‌شده شامل SQL صفر	مخرب SQL
Cross-Tenant و Scope رد تست‌های دسترسی خارج از ۱۰۰٪	کنترل دسترسی
عدم استفاده از سند نسخه دیگر مگر وابستگی صریح و تأییدشده	جداسازی نسخه
نامن Query توافق‌شده بدون اجرای adversarial عبور از مجموعه تست	Prompt/SQL Injection
کمتر از ۱ ثانیه در محیط مرجع Cache پاسخ P95	کارایی Cache

معیار پیشنهادی	شاخص
P95 کمتر از ۱۲ ثانیه، با تفکیک زمان Provider و شبکه	کارایی غیرکش
مطابق سناریوی تست مصوب Circuit Breaker مدل و Failover	پایداری
قابلیت ردیابی هر درخواست با Audit ID و لاگ‌های کامل و Redacted	ممیزی
تأیید سناریوهای پنل مالک، مدیر نرم‌افزار و اتصال بهساز	پذیرش کاربری

حجم دانش، دوره نگهداری لاگ و دسترس‌پذیری پس از دریافت ظرفیت ،RPS ،نهایی مانند تعداد کاربران هم‌زمان SLA اعداد قرارداد قطعی می‌شوند. SLA هدف و مشخصات زیرساخت در پیوست.

۱۲. ترکیب تیم پیشنهادی

نقش	تعداد	مسئولیت
مدیر پروژه/تحلیلگر کسب‌وکار	۱-۰.۵	UAT دامنه، برنامه، صورت‌جلسه، ریسک و
Tech Lead/معمار نرم‌افزار	۱	و تصمیم‌های فنی Review ،معماری، امنیت
Backend Engineer	۲	API، IAM، Billing، Knowledge و Integration
AI/NL2SQL Engineer	۲-۱	RAG، Graph، Planner، Model Router و Evaluation
Frontend Engineer	۱	Next.js، Tailwind، RTL و پنل‌ها
DevOps/SRE	۱-۰.۵	CI/CD، Observability، Security و Deployment
QA/Automation	۱	Regression تست خودکار، بار، امنیت و
کارشناس دیتابیس کارفرما	مشارکتی	های طلایی و قواعد کسب‌وکارQuery ،اسکیما

۱۳. پیش‌نیازهای کارفرما

- معرفی مالک محصول، نماینده امنیت، کارشناس دیتابیس و مدیر نرم‌افزار بهساز.
- های تأییدشده بدون داده شخصی غیرضروریQuery ها، روابط، قواعد کسب‌وکار وView ،واقعی DDL ارائه.
- یا نتیجه مورد انتظار و داده آزمون ثابت Gold SQL تحویل ۲۰ سؤال پذیرش همراه با.
- User. و Organization ،Region های Scope ارائه ماتریس نقش/دسترسی و تعریف دقیق
- تعیین درگاه پرداخت، شیوه تعرفه، واحد شارژ، سیاست برگشت وجه و فرایند مالی.
- و حجم دانش RPS ،اعلام ظرفیت هدف :تعداد شهرداری، نرم‌افزار، نسخه، کاربران هم‌زمان.
- و زیرساخت مدل محلی در صورت انتخاب CI/CD دسترسی، DNS، TLS گواهی، Stage فراهم‌کردن محیط
- تأیید سیاست ارسال درخواست به مدل ابری و طبقه‌بندی داده‌های مجاز/غیرمجاز.
- On-Premise. داخل نرم‌افزار Connector و امکان همکاری برای توسعه API ارائه
- پاسخ‌گویی به موارد باز حداکثر ظرف دو روز کاری برای حفظ برنامه زمان‌بندی.

۱۴. ریسک‌ها و راهکار کنترل

ریسک	اثر	کنترل
کیفیت پایین یا تناقض اسناد	زیاد	Standardizer، Conflict Queue، Approval Gate و عدم انتشار سند مبهم
مستند Join یا مسیر FK نبود	زیاد	Schema Graph و تست نتیجه DBA منطقی با تأیید
تغییر نسخه‌های نرم‌افزار	متوسط	Snapshot، Delta Ingestion، Regression و Rollback
ابهام نقش و سطح دسترسی	زیاد	Policy Workshop و ماتریس دسترسی قبل از پیاده‌سازی
نوسان مدل ابری	متوسط	Timeout، Retry ،محدود Circuit Breaker و مدل محلی جایگزین
مدل محلی GPU کمبود	متوسط	Benchmark مدل/Quantization و تفکیک Pilot از Production
Stage بهساز یا API تأخیر	زیاد	Mock Server، Contract Test و تحویل زودهنگام SDK
تغییر دامنه پرداخت/مالی	متوسط	Adapter مستقل و Ledger برای درگاه منتخب
Scope افزایش بی‌ضابطه	زیاد	Change Request، برآورد اثر و تأیید کتبی

۱۵. موارد خارج از دامنه پایه

- تغییر در ساختار داخلی یا کد منبع نرم‌افزار بهساز، جز Connector توافق‌شده.
- پاک‌سازی و اصلاح داده‌های عملیاتی شهرداری یا طراحی Data Warehouse.
- خرید سرور، GPU، لایسنس تجاری، گواهی امنیت یا هزینه سرویس مدل ابری.
- ارسال داده نتیجه گزارش به Cloud یا تحلیل داده خام؛ مگر با قرارداد و طراحی امنیتی جداگانه.
- آموزش از صفر مدل پایه LLM؛ Fine-tuning محدود پس از جمع‌آوری داده معتبر قابل برآورد است.
- پشتیبانی ۲۴×۷ و SLA عملیاتی بلندمدت؛ پس از دوره تثبیت در قرارداد نگهداری جداگانه تعریف می‌شود.
- هزینه و شرایط مالی اجرای پروژه؛ پس از نهایی‌شدن ظرفیت SLA و پرسش‌های باز در پیشنهاد مالی مستقل ارائه می‌شود.

۱۶. پشتیبانی، تضمین و مدیریت تغییر

پس از پذیرش نهایی، ۳۰ روز پشتیبانی تثبیت برای رفع اشکالات منطبق با دامنه مصوب در نظر گرفته می‌شود. نقص، رفتاری است که با معیار پذیرش یا مستندات مصوب مغایر باشد. قابلیت جدید، تغییر سیاست کسب‌وکار، افزودن نرم‌افزار یا نسخه خارج از دامنه، برآورد و برنامه‌ریزی می‌شود Change Request.

افزودن Retrieval، پیشنهاد می‌شود پس از دوره تثبیت، قرارداد نگهداری شامل مانیتورینگ، به‌روزرسانی امنیتی، بازآموزی و بازبینی دوره‌ای مدل منعقد شود Gold Test.

۱۷. جمع‌بندی و پیشنهاد تصمیم

محدودیت عدم دسترسی مستقیم به دیتابیس شهرداری، نیاز به دانش نسخه‌ای، RFP، معماری پیشنهادی با الگوی استقرار متمرکز و RAG/NL2SQL چندمدلی‌بودن و کنترل هزینه سازگار است. مزیت اصلی پیشنهاد، استفاده از هسته تخصصی موجود در

تکمیل آن با اجزای سازمانی استاندارد است؛ در نتیجه پروژه از سطح نمونه نمایشی عبور کرده و به سکوی قابل ممیزی، توسعه‌پذیر و امن تبدیل می‌شود.

پیشنهاد تصمیم

تأیید فاز آغاز و تحلیل تفصیلی دو هفته‌ای، نهایی‌کردن پرسش‌های باز و سپس شروع برنامه ۲۰ هفته‌ای. در پایان هفته دوم، برنامه، SLA، مبنا ظرفیت و معیارهای پذیرش برای الحاق به قرارداد تثبیت می‌شوند.

پیوست الف: ماتریس انطباق با RFP

الزام RFP	وضعیت	پاسخ پیشنهادی
استقرار مرکزی و ارتباط امن API	کامل	Kong + Keycloak + TLS به DB؛ بدون اتصال مستقیم
اعتبارسنجی توکن و نسخه	کامل	Knowledge Snapshot و JWT/API Key
کنترل سطح دسترسی و موضوع	کامل	Policy Engine + Access Context
تولید SQL و نوع نمایش	کامل	Planner/Generator/Display Spec
جلوگیری از افشای ساختار	کامل	Schema Slice داخلی و Redacted فهرست اسکیما، خطای API عدم
Prompt Injection و SQL Injection	کامل	Parameterization، AST Guard و Adversarial Tests
مدیریت API Key و شارژ	کامل	Key Lifecycle، Wallet، Tariff و Quota
پنل مالک سامانه	کامل	مدیران، دسترسی، شارژ، پرداخت، آمار و لاگ
پنل مدیر نرم‌افزار	کامل	نرم‌افزار، نسخه، دانش، کاربر، کلید، مصرف و کیفیت
دانش نسخه‌ای و جایگزینی فایل	کامل	Snapshot، Hash، Delta، Approval و Rollback
چند مدل Cloud/Local و Failover	کامل	Model Router، Circuit Breaker و vLLM/TGI
بهبود مستمر	کامل	Feedback، Gold Tests، Dataset Promotion و Regression
کاهش هزینه با مشابهت	کامل	Exact/Semantic Cache با Access Fingerprint
گزارش‌های مدیریتی	کامل	TimescaleDB، Elasticsearch، Prometheus/Grafana
استک مورد تأیید	کامل	Vendor-Neutral: FastAPI/Keycloak/Kong/Next.js

پیوست ب: نمونه پاسخ API

نمونه زیر صرفاً برای تثبیت ساختار قرارداد است و نام جداول/ستون‌های واقعی پس از تحویل اسکیما و تأیید جایگزین DBA می‌شود.

فیلد	نمونه مقدار

فیلد	نمونه مقدار
status	success
sql	SELECT TOP (@limit) ... WHERE CaseNumber = @case_number
parameters	limit=20، case_number=...
display.type	table
display.title	آخرین پرونده‌های ماده ۱۰۰
policy	read_only=true، max_rows=20، timeout=10s
confidence	high
audit_id	شناسه یکتای قابل پیگیری

پیوست ج :پرسش‌های باز پیش از قرارداد

1. تعداد نرم‌افزارها، نسخه‌ها، شهرداری‌ها و کاربران هم‌زمان در سال اول چقدر است؟
2. هستند؟ SQL Server دیتابیس هر نرم‌افزار چیست و آیا همه نسخه‌ها Dialect
3. آیا سیاست دسترسی کاربران در نرم‌افزار مبدأ قطعی است یا سامانه مرکزی نیز مرجع دسترسی خواهد بود؟
4. مدل، زمان پردازش یا تعرفه ترکیبی است؟ Token ،تعریف »شارژ «بر اساس تعداد درخواست
5. درگاه پرداخت و الزامات مالی/مالیاتی مورد نظر کدام است؟
6. شوند؟ Mask/Hash آیا ذخیره متن کامل پرامپت مجاز است یا باید برخی فیلدها
7. مدل‌های ابری مجاز و سیاست خروج داده برای هر مشتری چیست؟
8. مدل محلی و سطح دسترس‌پذیری مورد انتظار چیست؟ GPU زیرساخت
9. پشتیبانی چه مقدار است؟ SLA لاگ و Retention، RPS، حداکثر زمان پاسخ
10. ثابت چه زمانی تحویل می‌شود؟ Dataset و Gold SQL ،تعریف دقیق ۲۰ سؤال پذیرش